Auditoría arquitectónica de Vivu

Corte: código base 4b330ad, 13 de noviembre de 2026. Alcance: revisión estática del monorepo, contratos, configuración, pruebas y documentación; las comprobaciones ejecutadas se informan en el PR. Se trata de una evaluación orientativa, no de una certificación ni de una medición exhaustiva en producción. No se accedió a datos reales ni se efectuaron pruebas de carga, intrusión o disponibilidad prolongada.

Método y contexto

Se utiliza ISO/IEC 25010:2023 (https://www.iso.org/standard/78176.html), modelo de calidad de producto de la familia SQuaRE, como referencia para organizar atributos, y Software Architecture in Practice, cuarta edición (https://insights.sei.cmu.edu/library/software-architecture-in-practice-fourth-edition/) (Bass, Clements y Kazman, 2021) para analizar componentes, conectores, escenarios y compromisos. Se consultaron las descripciones públicas de ambas fuentes; este documento no reproduce ni pretende aplicar íntegramente el texto normativo.

Las prioridades expresan juicio arquitectónico: P0 antes de uso compartido con datos reales; P1 antes de ampliar el piloto; P2 evolución posterior. Cada hallazgo se fundamenta en rutas del repositorio y debe verificarse nuevamente al cambiar el código.

Arquitectura observada

La web incluye clientes locales de autenticación y dominios; el cliente HTTP genérico existe, pero no se identificó su uso desde esos clientes. El gateway expone controladores y servicios de dominio que implementan reglas y estado propios, en lugar de conectarse mediante HTTP a los servicios homólogos. Los servicios tienen endpoints independientes. Compose inicia PostgreSQL y RabbitMQ y configura URL, pero sus validadores por sí solos no establecen conexión. Esto describe el código inspeccionado, no un despliegue externo.

Web → estado local
Evidencia: App.tsx (../apps/web/src/app/App.tsx), clientes (../apps/web/src/features/) y cliente HTTP (../apps/web/src/platform/http/api-client.ts)
Consecuencia: Las pruebas locales no acreditan un flujo completo hacia el backend.

Gateway → dominios
Evidencia: módulo (../apps/api-gateway/src/app.module.ts), recomendaciones (../apps/api-gateway/src/recommendation/gateway-recommendation.service.ts)
Consecuencia: El gateway reúne reglas y estado independientes; no se verificó delegación a los servicios.

Servicios → infraestructura
Evidencia: Compose (../docker-compose.yml), repositorio de misiones (../services/gamification-service/src/gamification/gamification.repository.ts), configuración Python (../services/recommendation-service/src/recommendation_service/config.py)
Consecuencia: Los repositorios y motor examinados utilizan memoria; URLs configuradas no equivalen a almacenamiento ni eventos operativos.

Salud → dependencias
Evidencia: salud de identity (../services/identity-service/src/health/health.controller.ts), salud Python (../services/recommendation-service/src/recommendation_service/main.py)
Consecuencia: ready devuelve un estado fijo; no demuestra disponibilidad de base de datos o broker.

Los ADR (adr/) describen decisiones y objetivos. Su presencia no prueba que estén implementados. Los diagramas y README de servicios recogen las capacidades observadas y enlazan esta evaluación.

Hallazgos y plan priorizado

A1
Prioridad y atributos: P0 • fiabilidad, integridad
Evidencia e impacto: Los repositorios (../services/student-service/src/student/student.repository.ts) y gateway (../apps/api-gateway/src/auth/gateway-auth.service.ts) usan mapas; el motor Python (../services/recommendation-service/src/recommendation_service/engine.py) también mantiene estado en proceso. Reiniciar o escalar puede perder o dividir datos y sesiones.
Acción propuesta: Definir ownership por dominio, persistencia transaccional, recuperación e idempotencia duradera; ensayar reinicio y múltiples instancias.

A2
Prioridad y atributos: P0 • seguridad
Evidencia e impacto: GatewayAuthService (../apps/api-gateway/src/auth/gateway-auth.service.ts) y TokenService (../services/identity-service/src/auth/token.service.ts) contienen valores de desarrollo por defecto; el gateway inicializa cuentas de ejemplo. .env.example usa JWT_ACCESS_SECRET mientras el código lee JWT_SECRET.
Acción propuesta: Prohibir credenciales de ejemplo fuera de desarrollo; exigir secreto gestionado y alineación de nombres, revisar cuentas iniciales y controles de despliegue.

A3
Prioridad y atributos: P1 • compatibilidad, mantenibilidad
Evidencia e impacto: Web, gateway y servicios poseen implementaciones paralelas; App (../apps/web/src/app/App.tsx) usa clientes predeterminados locales y AppModule (../apps/api-gateway/src/app.module.ts) registra proveedores locales.
Acción propuesta: Elegir propietario de cada regla, implementar conectores explícitos y contratos versionados; reemplazar duplicaciones gradualmente con pruebas de paridad.

A4
Prioridad y atributos: P1 • fiabilidad, observabilidad
Evidencia e impacto: Los endpoints ready examinados devuelven respuestas constantes; Compose comprueba health. Una respuesta exitosa no acredita disponibilidad de dependencias.
Acción propuesta: Separar vida y preparación; comprobar dependencias realmente requeridas, incorporar métricas, trazas y pruebas de fallos.

A5
Prioridad y atributos: P1 • privacidad, adecuación funcional
Evidencia e impacto: El consentimiento y las respuestas están en memoria y en implementaciones paralelas (student (../services/student-service/src/student/student.repository.ts), survey (../services/survey-service/src/survey/survey.repository.ts)); no se ha demostrado propagación del retiro.
Acción propuesta: Definir retención, acceso y eliminación; probar que el retiro se aplica a todos los flujos y copias antes de usar datos sensibles.

A6
Prioridad y atributos: P1 • adecuación funcional
Evidencia e impacto: Support (../services/support-service/src/app.module.ts) y analytics (../services/analytics-service/src/app.module.ts) solo registran salud; no se evidencia funcionalidad de negocio.
Acción propuesta: Establecer contratos y criterios de aceptación antes de anunciar esas capacidades.

A7
Prioridad y atributos: P2 • interoperabilidad, mantenibilidad
Evidencia e impacto: Compose (../docker-compose.yml) configura broker y bases; los validadores aceptan URLs opcionales. El catálogo de eventos (architecture/event-catalog.md) documenta contratos, no demuestra publicación/consumo.
Acción propuesta: Acordar eventos y garantías de entrega, implementar productores y consumidores si son necesarios y probarlos con infraestructura real.

Compromiso principal: centralizar reglas y persistencia mejora consistencia y seguridad, pero introduce latencia, dependencias de red y necesidades de operación. Definir tiempos límite, comportamiento ante caídas y estrategia offline antes de conectar componentes. No se propone un cambio de ADR como decisión ya tomada.

Atributos y escenarios

Adecuación funcional
Estado basado en evidencia: Hay reglas y pruebas de dominio; support y analytics son esqueletos.
Escenario y medida propuesta, no resultado medido: Una persona completa una misión y la consulta tras reiniciar: resultado y progreso deben coincidir; medir pruebas de extremo a extremo aprobadas.

Eficiencia de desempeño
Estado basado en evidencia: Sin mediciones de carga ni objetivos operativos.
Escenario y medida propuesta, no resultado medido: En carga piloto acordada, medir latencia p95 y errores de acciones clave; fijar umbrales con producto.

Compatibilidad e interoperabilidad
Estado basado en evidencia: Contratos y contenedores existen; integración distribuida no demostrada.
Escenario y medida propuesta, no resultado medido: Ante una nueva versión de contrato, ejecutar pruebas de consumidor y proveedor y registrar incompatibilidades.

Capacidad de interacción
Estado basado en evidencia: Hay interfaz y pruebas; no se realizó evaluación con usuarios ni auditoría de accesibilidad.
Escenario y medida propuesta, no resultado medido: Completar tareas clave con teclado y tecnología asistiva; medir bloqueos y acordar criterios de accesibilidad.

Fiabilidad
Estado basado en evidencia: Estado volátil y readiness fija limitan recuperación observable.
Escenario y medida propuesta, no resultado medido: Tras reiniciar un componente con una acción confirmada, verificar conservación y ausencia de duplicados; acordar RPO/RTO.

Seguridad
Estado basado en evidencia: Hay controles de roles y hash; secretos y cuentas de desarrollo son riesgos para uso compartido.
Escenario y medida propuesta, no resultado medido: Intentar acceso sin permiso y con credenciales de ejemplo en entorno no local: debe rechazarse y quedar registrado.

Mantenibilidad
Estado basado en evidencia: Monorepo, ADR y pruebas facilitan cambios; reglas duplicadas elevan riesgo de divergencia.
Escenario y medida propuesta, no resultado medido: Cambiar una regla en su propietario y ejecutar contratos y pruebas de consumidores; medir ubicaciones que requieren modificación.

Flexibilidad
Estado basado en evidencia: Compose y workspaces facilitan arranque; portabilidad de datos y despliegue real no medidos.
Escenario y medida propuesta, no resultado medido: Levantar una instalación limpia con configuración documentada y verificar servicios sin ajustes manuales no documentados.

Seguridad operacional (safety)
Estado basado en evidencia: No se ha evaluado el daño potencial de recomendaciones ni su gestión integral.
Escenario y medida propuesta, no resultado medido: Ante una recomendación inadecuada, verificar rechazo, explicación y revisión humana según criterios acordados.

Los nombres de atributos se presentan en español como traducciones de trabajo; no son una evaluación formal de todas las subcaracterísticas. No se asignan puntuaciones sin métricas, objetivos y mediciones consensuados.

Secuencia sugerida

1. Antes de datos reales: corregir secretos y cuentas de ejemplo, acordar clasificación y ciclo de vida de datos, y diseñar persistencia y recuperación (A1, A2, A5).

2. Antes de ampliar el piloto: establecer límites de dominio y conectores, integrar web y servicios, probar autorización y fallos entre procesos; completar observabilidad (A3, A4, A6).

3. Evolución: validar necesidad de mensajería, medir desempeño y accesibilidad, y mantener decisiones y contratos con evidencia (A7).

Los umbrales, responsables y fechas requieren acuerdo del equipo; el orden es una recomendación, no una promesa de entrega. Informe visual (informe-auditoria.html).